

ICT Risk Management Professional

DORA Capstone Scenario — Cloud-Hosted Instant Payment Platform — Azure Environment
Musterbank GmbH · Critical or Important Function (CIF) · Concentration Risk Declared

Prepared by: Shingirai Marenga | ISO 27001 Lead Auditor | CISM | CISSP | ICT Risk Management Professional | Regulatory context: DORA (EU 2022/2554), BAIT, MaRisk, §25b KWG | June 2026

Scenario Overview

Musterbank GmbH, a BaFin-regulated credit institution, is launching a new cloud-hosted instant payment platform to meet PSD2 SEPA Instant requirements. The platform is fully hosted on **Microsoft Azure** in the EU (West Europe — Netherlands) region and will process retail and SME payment transactions 24/7. As ICT Risk Officer, I am required to demonstrate that the full DORA ICT risk management framework — including all applicable RTS and ITS obligations — has been applied before go-live. This document is consistent with the Musterbank ICT Risk Register (June 2026) and the DORA Gap Analysis (June 2026).

Azure Environment Note: All compute, storage, networking, identity and key management services referenced in this document are deployed on Microsoft Azure (West Europe — Netherlands primary; North Europe — Ireland secondary DR region). Microsoft Azure is the sole cloud service provider. This creates a concentration risk that is formally declared in Section 6 and cross-referenced to Risk Register R-003 (Gross Risk 25 — Critical; CE 25%).

1. CIF Classification Art. 6(1) | Art. 3(22) DORA | BAIT §2 | §25b KWG

The first governance obligation is to formally determine whether the payment platform meets the threshold for a Critical or Important Function (CIF). Under DORA Article 3(22), a function is critical or important when its disruption would materially impair financial performance, service continuity, or compliance with regulatory obligations. Three criteria are assessed against the RTS on the ICT risk management framework (Mandate #1):

CIF Criterion	Assessment	Outcome
Customer-facing revenue generation	Platform processes 100% of Musterbank retail and SME payment transactions via Azure; no manual fallback channel exists for SEPA Instant.	✓ Meets threshold
Regulatory continuity (§25b KWG / BAIT §2)	Azure outage triggers a reportable incident under BAIT §25(1), MaRisk AT 7.2, and a potential DORA Art.19 major incident notification obligation.	✓ Meets threshold
Reputational and systemic impact	Prolonged Azure outage causes customer-visible payment failures and triggers BaFin notification under Art. 19 DORA; reputational and contractual penalty exposure.	✓ Meets threshold

Governance action: CIF classification documented in the Musterbank CIF-Register (CIF-REF: MB-CIF-2026-001), signed off by the CRO and IT Risk Committee. Entry added to the DORA Register of Information (Art. 28(3)) identifying Azure as the supporting ICT TPP. Under BAIT §2, classification triggers heightened IT oversight for all material outsourcing. Microsoft Azure is designated a Critical ICT Third-Party Provider (CTPP) and entered in the Auslagerungsregister per §25b KWG with risk classification *wesentlich*.

2. ICT Asset Inventory & Dependency Mapping Art. 8 DORA | BAIT §4 | RTS Mandate #1 | ITS

Mandate #8

DORA Article 8 and the RTS on the ICT risk management framework require a continuously maintained, criticality-classified inventory of all ICT assets supporting the CIF. The inventory is structured by layer and maps to the DORA Register of Information (ITS Mandate #8). All infrastructure components are Azure-native services deployed in West Europe (primary) with DR failover to North Europe (Ireland).

Asset Layer	Azure Services / Components	Criticality	Owner
Application	Payment core engine (Azure VMs / Azure Container Instances); Azure API Management (APIM); fraud detection module (Azure Functions + Azure Machine Learning); transaction ledger (Azure Database for PostgreSQL - Flexible Server Zone-Redundant)	Critical	Musterbank IT
Platform (Azure CSP)	Azure VMs / ACI compute (West Europe); Azure Blob Storage (versioning + geo-replication to North Europe); Azure Key Vault HSM-backed key management; Azure Kubernetes Service (AKS); Azure Key Vault (Secrets)	Critical	Azure — SLA 99.99%
Network	Azure ExpressRoute (dedicated 1 Gbps to Musterbank DC); VNet with private subnets; Azure Virtual WAN; Azure DNS / Azure Traffic Manager; Azure Front Door CDN; Azure DDoS Protection Standard	Critical	Azure / Musterbank shared
Identity & Access	Azure Active Directory (Entra ID) RBAC (least-privilege); Azure Entra ID SSO; CyberArk PAM integrated via SAML; Azure MFA (hardware tokens — YubiKey); Azure Monitor Activity Log (immutable audit log of all API calls)	Critical	IT Security
Monitoring & Detection	Azure Monitor (metrics + alarms); Microsoft Defender for Cloud (threat detection + vulnerability assessment); Azure Activity Log; Splunk SIEM (Azure Monitor Logs forwarded via Azure Event Hubs); Azure Policy (configuration compliance); Azure Network Watcher (NSG Flow Logs)	Important	SOC / IT Ops
Data	Azure Database for PostgreSQL Zone-Redundant (West Europe, EU data residency confirmed); Azure Blob Storage encrypted backups (AES-256, Azure Key Vault managed); Azure Cosmos DB (session/audit log store); Azure Backup (automated daily snapshots + geo-redundant copy to North Europe)	Critical	Data Management
External Dependencies	SEPA clearing: Deutsche Bundesbank TARGET2 (via Azure ExpressRoute VPN); SWIFT Alliance Gateway (on-premise, MFA-enforced); Four-eyes authorisation service (Musterbank-hosted)	Critical	Third parties

Concentration Risk (R-003): The entire payment platform — compute, storage, network, identity and key management — runs on a single cloud provider (Microsoft Azure West Europe). This constitutes a concentration risk under DORA Art. 29 and BaFin cloud outsourcing Merkblatt. A formal concentration risk statement is submitted to BaFin (see Section 6). Consistent with ICT Risk Register R-003 (Gross Risk 25 — Critical; CE 25%).

3. Protective Controls

Art. 9–10 DORA | BAIT §6–§8 | RTS Mandate #1

Article 9 of DORA and the ICT risk management RTS require protection and prevention measures proportionate to the CIF risk profile. All controls are implemented using native Azure security services alongside Musterbank-managed tooling. Controls map to the RTS lifecycle domains: Govern, Identify, Protect, Detect, Respond, Recover.

Control Domain	Azure Service / Control Implemented	DORA / BAIT Ref	Status
Identity & Access (IAM)	Azure RBAC (least-privilege, no wildcard role assignments); Azure Entra ID SSO; CyberArk PAM for privileged admin accounts (88% coverage — 100% target by go-live); YubiKey hardware MFA for all payment system access; quarterly access recertification via Azure Entra ID Access Reviews; Azure Monitor Activity Log (immutable audit log of all API calls)	Art. 9(2) BAIT §6	■ Partial (PAM 88%)

Control Domain	Azure Service / Control Implemented	DORA / BAIT Ref	Status
Cryptography & Key Management	TLS 1.3 enforced in transit (Azure Application Gateway + APIM policies); AES-256 encryption at rest (Blob Storage, PostgreSQL, Cosmos DB — Azure Key Vault managed); Azure Key Vault HSM-backed keys (FIPS 140-2 validated); Key rotation: annual automatic rotation enabled; Azure Key Vault (Secrets) for credentials — no hardcoded secrets; Azure Dedicated HSM evaluated for highest-sensitivity key material	Art. 9(3) BAIT §8(4)	✓ Complete
Network Isolation	Payment platform in isolated VNet (West Europe); private subnets only — no direct internet egress; Azure Web Application Firewall (OWASP Top 10 rule set + custom payment API rules); Azure DDoS Protection Standard (24/7 DDoS Response Team); NSGs + Azure Firewall (deny-by-default); NSG Flow Logs → Splunk SIEM; Azure Firewall at perimeter; Azure ExpressRoute (private 1 Gbps — no public internet path to core services)	Art. 9(2) BAIT §7	✓ Complete
Vulnerability Management	Microsoft Defender for Cloud (continuous VM + container vulnerability assessment); Azure Update Manager (automated patching — critical CVEs within 72h); Azure Policy / CIS Azure Foundations Benchmark; DAST: Burp Suite Enterprise in CI/CD pipeline (74% coverage — pre-go-live target ≥90%); Annual external penetration test (scope: Azure perimeter, APIM, payment API)	Art. 10 BAIT §8(3)	■ Partial (DAST 74%)
Logging & Detection	Azure Monitor Activity Log (all API activity, immutable Blob Storage archive); Azure Monitor (metric alarms — latency, error rate, availability); Microsoft Defender for Cloud (ML-based threat detection — enabled across all subscriptions); Azure Policy (continuous compliance rules — 47 rules enabled); Splunk SIEM integration via Azure Event Hubs; SOC monitoring 24/7 with 15-min alert-to-action SLA	Art. 9 BAIT §8	✓ Complete
Data Protection & Privacy	All PostgreSQL and Blob Storage data encrypted at rest (Azure Key Vault managed); EU data residency confirmed — West Europe only (Blob Storage public access disabled; Azure Blob Storage immutability policies for audit logs); dev/test environments: payment data masking in progress (partial gap — TREAT item); DSGVO Art. 32 technical measures documented	Art. 9(3) DSGVO Art.32	■ Partial (Dev/Test gap)

4. Business Impact Analysis – RTO / RPO Art. 11(6) DORA | MaRisk AT 7.3 | BAIT §9

A Business Impact Analysis was conducted by Business Continuity Management in coordination with IT Risk. The BIA quantified financial, regulatory and reputational impact across three Azure outage duration scenarios, anchored to SEPA Instant Credit Transfer rules and the DORA Art. 19 major incident notification threshold.

Metric	Approved Value	Justification
Recovery Time Objective (RTO)	1 hour	SEPA Instant Credit Transfer rules require settlement within 10 seconds; Azure region failover to North Europe (Ireland) triggers at 15 minutes downtime; RTO validated via semi-annual DR failover test.
Recovery Point Objective (RPO)	5 minutes	Azure Database for PostgreSQL Zone-Redundant synchronous replication provides near-zero RPO; Azure Backup geo-redundant snapshots every 5 minutes for transaction DB; no more than 5 minutes of payment data loss tolerable without reconciliation failure.
Maximum Tolerable Period of Disruption (MTPD)	4 hours	Beyond 4 hours, reputational damage, SEPA scheme penalties, BaFin supervisory escalation and Art. 19 DORA major incident reporting become unavoidable.

5. Continuity and Recovery Planning Art. 11 DORA | BAIT §9 | MaRisk AT 7.3 | ISO 22301

Musterbank's BCM framework is aligned to ISO 22301 and MaRisk AT 7.3. For the Azure-hosted payment platform, three plan types are maintained. Azure region failover (West Europe → North Europe) is the primary recovery mechanism for cloud outage scenarios.

Plan	Key Elements	Test Frequency
Business Continuity Plan (BCP)	• Crisis escalation tree: IT Risk → CRO → Management Board • Customer communication templates (BaFin Art. 19 notifiable language) • Manual fallback: SEPA batch processing via domestic correspondent bank • RACI matrix; Azure Incident Response runbook integrated • BaFin notification workflow: automated trigger at DORA major incident threshold	Annual tabletop + quarterly review
Disaster Recovery Plan (DRP)	• Azure active/passive failover: West Europe (primary) → North Europe (DR) • Automated failover trigger: Azure Traffic Manager health checks; 15-min downtime threshold • Azure Database for PostgreSQL read-replica promotion in North Europe (target: <5 min) • Azure Site Recovery for VM workloads • Backup restoration runbook: Azure Backup + geo-redundant Blob Storage restore • Post-recovery reconciliation procedure (RPO validation via Azure Monitor)	Semi-annual technical DR test
Exit Plan (Auslagerungsregister)	• Documented Azure-to-alternative-CSP migration path (12-month runway) • Data portability: Azure Blob Storage export + PostgreSQL snapshot portability confirmed • Interim operating model during transition to alternative provider • Exit plan referenced in Auslagerungsregister per §25b KWG • Annual board review — consistent with Gap Analysis Art. 28(7) finding	Annual review (§25b KWG)

6. ICT Third-Party Risk – Azure as Critical ICT TPP Art. 28–30 DORA | §25b KWG | BAIT §9–§10 | RTS Mandates #7, #9 | ITS Mandate #8

Because the payment platform is fully hosted on Microsoft Azure, Microsoft Ireland Operations Ltd is a Critical ICT Third-Party Service Provider (CTPP) under DORA Art. 28. This triggers the full set of enhanced third-party risk management obligations under DORA and §25b KWG, beyond standard outsourcing governance. The RTS on the policy on ICT services supporting critical functions (Mandate #7) and the RTS on subcontracting (Mandate #9) both apply.

6a — Pre-Contract Due Diligence & Ongoing Monitoring (Art. 28(4), 28(6))

Obligation	Musterbank Action
Pre-contract due diligence (Art. 28(4))	Security posture review: Azure ISO 27001, SOC 2 Type II, PCI DSS, CSA STAR Level 2 certificates reviewed; financial stability confirmed (public entity — Microsoft Corporation); sub-processor mapping obtained (Azure uses sub-processors for CDN, DNS, DDoS — documented); EU data residency confirmed: West Europe data does not leave EU without explicit consent; Azure Shared Responsibility Model documented and accepted.
Ongoing monitoring (Art. 28(6))	Annual Azure security posture review (SOC 2 Type II re-certification checked); Azure Service Health monitored daily; quarterly CSP service reports reviewed by IT Risk; Azure Advisor findings reviewed monthly; concentration risk reported to Risk Committee annually.
Auslagerungsregister (§25b KWG)	Entry created: Microsoft Ireland Operations Ltd — service description (IaaS/PaaS/cloud infrastructure); CIF linkage (MB-CIF-2026-001); risk classification: wesentlich; contract dates; exit plan reference; BaFin-reportable flag: Yes; concentration risk flag: Yes (70% of critical ICT services on single provider).
Register of Information (Art. 28(3), ITS Mandate #8)	Azure entry added to DORA Register of Information per EBA ITS RTS template: provider identified by LEI; services classified; CIF linkage documented; sub-outsourcing chain (CDN, DNS, DDoS sub-processors) mapped; substitutability and exit arrangement fields completed. Register submitted to BaFin by 30 April 2025 deadline.

6b — Article 30 Mandatory Contractual Content (Art. 28(5)–(9), Art. 30)

DORA Article 30 specifies the mandatory clauses that every contract for ICT services supporting a critical or important function must contain. The RTS on subcontracting (Mandate #9) extends these obligations through the sub-processor chain. All clauses below are verified in the Musterbank–Azure Enterprise Agreement and Azure Data Processing Addendum (DPA):

Art. 30 Mandatory Clause	Musterbank–Azure Implementation	Status
Clear description of services, service levels and data locations (Art. 30(2)(a))	Azure Enterprise Agreement schedules: compute (VMs/ACI), storage (Blob/PostgreSQL), network (VNet/ExpressRoute), security (Key Vault/Defender for Cloud/WAF). SLA: 99.99% for VMs + PostgreSQL Zone-Redundant. Data location: West Europe explicitly stated; Blob Storage policies enforce EU residency.	✓ Met
Availability, continuity and performance obligations (Art. 30(2)(b))	Azure SLA: 99.99% monthly uptime for VMs (Zone-Redundant); 99.99% for Azure Database for PostgreSQL Zone-Redundant; 99.9% for Blob Storage. Downtime credits contractually enforceable. Incident notification within 4 hours (aligned to DORA Art. 19 threshold) included in DPA.	✓ Met
Security — confidentiality, integrity, availability (Art. 30(2)(c))	Azure Shared Responsibility Model documented: Azure responsible for infrastructure security; Musterbank responsible for data, identity, application security. Azure commits to ISO 27001, SOC 2 Type II, PCI DSS Level 1, GDPR/DSGVO compliance. Encryption obligations and key management documented in DPA.	✓ Met
Assistance with incident management (Art. 30(2)(d))	Azure Unified Support (24/7 — included in Enterprise Agreement); Microsoft Security Response Center: dedicated team for confirmed security events; Azure DDoS Rapid Response (DRR): 24/7 engagement for DDoS Protection Standard customers; Forensic support (Azure artefact access) at no additional charge during incidents.	✓ Met
Audit and inspection rights — entity and supervisors (Art. 30(2)(e))	Azure Enterprise Agreement grants Musterbank: access to Microsoft Service Trust Portal (SOC reports, ISO certificates); right to conduct audits (with notice) or commission third-party audits; BaFin and ECB supervisory access rights explicitly included (DORA Art. 30(2)(e) clause); audit rights extend to relevant sub-processors (CDN, DNS, DDoS providers) per Mandate #9.	✓ Met
Subcontracting conditions and notification of changes (Art. 30(2)(f), RTS Mandate #9)	Azure sub-processor list (CDN: Azure Front Door; DNS: Azure DNS; DDoS: Azure DDoS sub-processors) contractually listed; material changes notified to Musterbank with 30-day notice; Musterbank retains right to object or exit on material sub-processor changes; audit rights extend through sub-processor chain per RTS Mandate #9.	✓ Met
Termination rights and exit assistance (Art. 30(2)(g))	Termination for convenience: 30-day notice (Musterbank); termination for material breach: immediate; exit assistance: Azure commits to 12-month transition support post-termination; data deletion/export: Azure Blob Storage export tools + PostgreSQL snapshot export provided; data deletion certificate issued within 60 days of termination.	✓ Met
Cooperation with supervisors and CTPP oversight (Art. 30(2)(h))	Azure cooperates with the DORA Oversight Framework (EBA Lead Overseer if designated as CTPP); Musterbank must factor Lead Overseer recommendations on Azure into its own risk decisions; supervisory information requests: Azure contractually committed to respond within 10 business days.	✓ Met

6c — Azure Concentration Risk Declaration (Art. 29 DORA | BaFin Cloud Merkblatt)

Concentration Risk — R-003 (ICT Risk Register): Azure hosts 70% of Musterbank's critical ICT services. This exceeds the DORA Art. 29 concentration risk guidance threshold. A formal concentration risk statement has been submitted to BaFin per the BaFin cloud outsourcing Merkblatt. Mitigation: multi-cloud roadmap initiated (AWS EU pilot — Q3 2026); target: reduce single-provider concentration to ≤55% by end 2027. Risk Register R-003: Gross 25 — Critical; CE 25% (exit plan Phase 1 only; Art. 30 clauses 60% complete). Concentration risk reported to Risk Committee annually.

7. Resilience Testing Programme Art. 24–27 DORA | BAIT §8(3) | RTS Mandate #6 | TIBER-EU

Articles 24–27 require all CIF-supporting systems to be included in the annual Digital Operational Resilience Testing (DORT) programme. All tests below are scoped to the Azure environment. TLPT applies if Musterbank meets the Art. 26 significance thresholds (to be confirmed with BaFin — currently assessed as likely applicable given payment CIF status).

Test Type	Azure Scope	Frequency	Outcome Measure
Vulnerability Assessment (Defender for Cloud)	Azure VMs, ACI containers, Azure Functions, Entra ID policy analysis; Azure Policy rules compliance; Defender for Cloud findings review	Continuous + quarterly review	Zero critical open > 30 days; Defender for Cloud Secure Score ≥90%
Penetration Test (external provider)	Azure perimeter (Internet-facing Application Gateway, APIM, Azure Front Door); payment API business logic; Entra ID misconfiguration; Blob Storage access controls; VNet network segmentation	Annual	No high/critical unmitigated findings at sign-off
DR Failover Test (Azure West Europe → North Europe)	Azure Traffic Manager failover: West Europe → North Europe; PostgreSQL read-replica promotion; ACI workload restart in DR region; Azure Backup geo-redundant restore validation; payment transaction reconciliation post-failover	Semi-annual	RTO ≤ 1h; RPO ≤ 5 min achieved and evidenced
BCP Tabletop	Azure region total outage scenario; crisis escalation; BaFin Art. 19 notification workflow test; manual SEPA batch fallback execution; customer communication	Annual	All decision points executed correctly; notification within 4h
TLPT (TIBER-EU aligned)	Live Azure production environment: payment API, Entra ID, VMs, ACI, Key Vault; threat-intelligence-led scope; red-team adversary simulation; blue team (SOC) kept blind; white team oversight	Every 3 years (if designated)	Findings remediated per TIBER-EU framework; supervisory attestation submitted to BaFin
Backup Restoration Test (Azure Backup)	Full PostgreSQL snapshot restore from geo-redundant Blob Storage (North Europe); Azure Cosmos DB point-in-time recovery; data integrity hash verification; reconciliation against transaction log	Quarterly	100% data integrity; restore completed within RPO (5 min)
Cloud Config Compliance Test	Azure Policy managed rules: CIS Azure Foundations Benchmark v2.0; DORA-specific custom policies (encryption, logging, IAM, network isolation); Microsoft Defender for Cloud automated assessment	Monthly	Zero critical non-conformances; 100% policy compliance

8. Five-Step ICT Risk Assessment Art. 8–13 DORA | ISO 27001:2022 Cl. 6.1 | NIST SP 800-30

Step 1 – Scope Definition

Scope: All Azure ICT assets, processes and third parties supporting the Musterbank cloud-hosted instant payment platform (CIF-REF: MB-CIF-2026-001). Primary region: West Europe (Netherlands). DR region: North Europe (Ireland). Exclusions: front-end mobile banking app (separate risk assessment, R-009 in Risk Register); back-office GL system (not in payment processing chain).

Step 2 – Identify Threats and Vulnerabilities

Threat	Azure-Specific Vulnerability	Category
Ransomware / destructive malware	Azure VM admin workstation endpoint controls incomplete; Azure Disk snapshots not immutable by default; Blob Storage immutability policies not applied to all containers	Cyber

Threat	Azure-Specific Vulnerability	Category
Azure region outage (CSP failure)	Active/passive architecture only (not active/active); Azure Traffic Manager failover adds 15-min latency; single-region primary dependency	Availability
Insider threat / privileged abuse	CyberArk PAM at 88% coverage; 2 shared Entra ID admin accounts outstanding; Entra ID Access Reviews not enforced on all subscriptions	Human
API injection / business logic abuse	Azure WAF rule set partially deployed; schema validation not yet enforced on all APIM endpoints; DAST pipeline coverage 74%	Cyber
Data breach / exfiltration	Payment data present in non-encrypted dev/test environments (Blob Storage containers); data masking remediation in progress	Data Protection
Azure sub-processor compromise	Limited visibility into Azure CDN/DNS sub-processor security posture; fourth-party risk assessment not completed	Third-Party
Entra ID misconfiguration	Overly permissive role assignments detected in Defender for Cloud (remediation in progress); Blob Storage ACLs not uniformly disabled	Cyber

Step 3 – Assess Likelihood and Impact (Rating: 1–5 Low | 6–10 Medium | 11–15 High | 16–25 Critical)

Risk Scenario	Likelihood (1–5)	Impact (1–5)	Gross Risk Score	Rating
Azure region outage — payment unavailability	4	5	20	Critical
Ransomware encrypting Azure payment database	3	5	15	High
Data breach of payment records (dev/test gap)	3	5	15	High
API abuse / fraudulent transaction injection	3	4	12	High
Entra ID misconfiguration / privilege escalation	3	4	12	High
Insider privilege abuse	2	4	8	Medium
Azure sub-processor compromise	2	4	8	Medium

Step 4 – Evaluate Controls and Residual Risk (CE Scale: 0%=None | 25%=Weak | 50%=Partial | 75%=Effective | 90%=Strong | 95%=Optimised)

Risk Scenario	Key Azure Controls Applied	CE (%)	Residual Score	Rating
Azure region outage	Azure Traffic Manager active/passive failover; DR in North Europe; semi-annual DR test; RTO 1h validated	50%	10	Medium
Ransomware	EDR on admin workstations; Azure Blob Storage immutability policies; Azure Backup geo-redundant; IR runbook; Defender for Cloud	75%	4	Low
Data breach (dev/test)	Encryption at rest (Azure Key Vault managed); dev/test data masking in progress (partial gap — TREAT item)	50%	8	Medium
API abuse	Azure WAF deployed; schema validation pre-go-live; DAST (74% coverage — pre-go-live target ≥90%)	50%	6	Medium
Entra ID misconfiguration	Entra ID Access Reviews; Defender for Cloud; Azure Policy rules; CyberArk PAM (88%); quarterly recertification	75%	3	Low

Risk Scenario	Key Azure Controls Applied	CE (%)	Residual Score	Rating
Insider abuse	PAM full deployment by go-live; Azure Monitor Activity Log immutable logs; quarterly access reviews	75%	2	Low
Sub-processor compromise	Azure DPA sub-processor list; 30-day notification; audit rights in contract	25%	6	Medium

Step 5 – Decision Against Board-Approved ICT Risk Appetite

Musterbank's Board-approved ICT Risk Appetite Statement (reviewed annually by the Risk Committee under DORA Art. 5) defines the following thresholds for CIF-supporting systems. Risk ratings use the scale: 1–5 Low | 6–10 Medium | 11–15 High | 16–25 Critical.

Appetite Dimension	Threshold	Risk Scenario	Residual vs Appetite	Decision
Availability	Max outage 1h; 99.95% uptime	Azure region outage	Residual 10 (Medium) — RTO 1h, DR tested; active-active not yet deployed	TREAT — pre-go-live DR validation required
Cyber resilience	No critical finding unmitigated > 30 days	Ransomware / API abuse	Ransomware: residual 4 (Low). API WAF: borderline — pre-go-live remediation required	TREAT — pre-go-live control required
Data protection	No unencrypted sensitive data in non-prod	Data breach	Dev/test masking in progress; partial gap remains	TREAT — deadline before go-live
Third-party	CTPP must hold ISO 27001 / SOC 2; exit plan documented	Sub-processor compromise	Azure certified; sub-processor review pending; exit plan Phase 1 only — concentration risk declared	ACCEPT with enhanced monitoring
IAM / Access	Zero shared admin accounts; PAM 100%	Entra ID misconfiguration / insider abuse	2 shared admins outstanding; PAM 88% — must reach 100% before go-live	TREAT — pre-go-live mandatory

Go/No-Go Recommendation: The platform should NOT be promoted to production until the following TREAT items are closed and evidenced: (1) Azure WAF full deployment and DAST coverage ≥90%; (2) dev/test payment data masking complete — no unencrypted PII/payment data in non-production Blob Storage containers; (3) PAM coverage 100% and zero shared Entra ID admin accounts; (4) Azure region DR failover test passed (RTO ≤1h / RPO ≤5min). Consistent with DORA Art. 6(5): the ICT risk management framework must be in place before deploying a CIF. Go-live sign-off gate chaired by CRO with IT Risk and Business sign-off.

Executive Conclusion & Go-Live Checklist

The Azure-hosted instant payment platform is a formally classified CIF (MB-CIF-2026-001). All eight DORA framework requirements have been addressed. Four pre-go-live TREAT items must be closed before production promotion. Findings are consistent with the Musterbank ICT Risk Register (June 2026) and DORA Gap Analysis (June 2026).

#	DORA / Regulatory Obligation	Status
1	CIF classification documented and board-approved; Auslagerungsregister updated (Art. 6, §25b KWG)	COMPLETE
2	ICT Asset Inventory complete with Azure service mapping; linked to Register of Information (Art. 8, ITS #8)	COMPLETE
3	Protective controls deployed: network isolation, cryptography, logging — PAM 88%; DAST 74% (Art. 9–10 BAIT §6–§8)	PARTIAL — PAM 100% and DAST ≥90% required before go-live

#	DORA / Regulatory Obligation	Status
4	BIA conducted; RTO 1h / RPO 5min / MTPD 4h board-approved and anchored to SEPA Instant rules (Art. 11)	COMPLETE
5	BCP and DRP documented; Azure West Europe → North Europe failover designed; DR test pending (Art. 11 BAIT §9)	PARTIAL — DR failover test must pass before go-live
6	Azure CTPP risk managed: Art. 30 all 8 mandatory clauses verified; sub-processor chain documented; concentration risk declared to BaFin (Art. 28–30 §25b KWG RTS #7, #9)	COMPLETE
7	Azure in DORT programme: vulnerability assessment (Defender for Cloud), pen test, DR test, BCP tabletop, TLPT scoped (Art. 24–27)	COMPLETE — first annual test cycle scheduled
8	Five-step ICT risk assessment completed; 3 TREAT items outstanding (Art. 8–13)	PARTIAL — TREAT items must be closed before go-live
9	Register of Information submitted to BaFin per EBA ITS RTS template (Art. 28(3), ITS Mandate #8)	COMPLETE
10	Azure concentration risk formally declared; multi-cloud roadmap initiated; AWS EU pilot Q3 2026; target ≤55% by 2027 (Art. 29, R-003)	COMPLETE — ongoing mitigation